# GearLoop

Campus gear lending, shipped the DevSecOps way

Netram Faran · 24BCS10329 · github.com/netram75/devsecops-python

# What GearLoop does

Students reserve cameras, drones, audio kits, lab kits, laptops and VR headsets; staff check items out, take them back and chase overdue loans.

## No double lending

Asset row locked (FOR UPDATE) before the overlap check → 409

## State machine

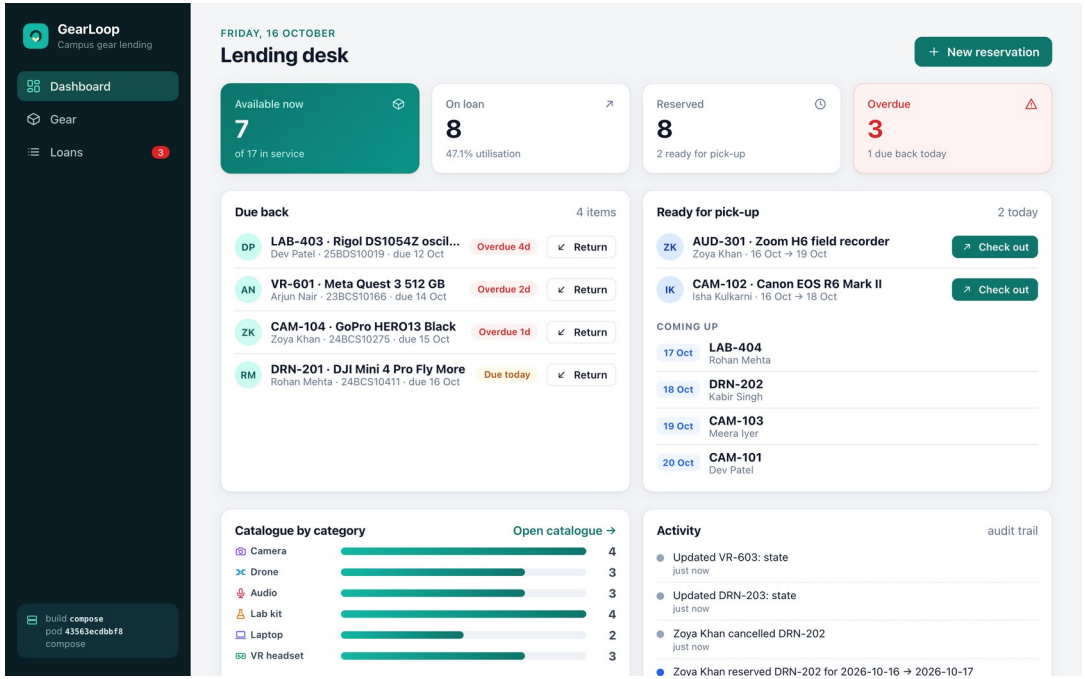
reserved → checked out → returned; illegal moves → 409

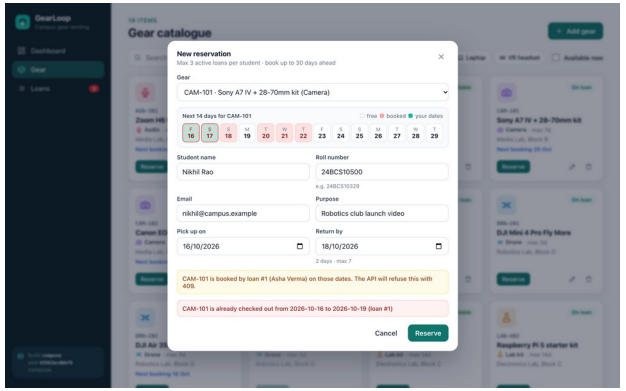
## Fair use

≤ 3 active loans per student (advisory lock); max days per category

## Audit + metrics

every change in an events table; overdue count is a Prometheus gauge




**32**
pytest cases, 92% coverage

**15**
REST operations

**3**
tables, 2 migrations

# Tech stack

### Application

FastAPI · SQLAlchemy 2 · Alembic · React 19 + Vite · PostgreSQL 17

### Testing

pytest + coverage on a throwaway SQLite DB built by the real migrations

### Containers

Multi-stage images · non-root (UID 10001 / 101) · docker compose

### CI/CD

GitHub Actions (9 jobs) · GHCR · tags = commit SHA

### Security

Trivy · Gitleaks · Bandit · npm audit · Pod Security restricted

### Kubernetes

kind (1 + 2 nodes) · Helm chart · ingress-nginx · HPA · PDB

### GitOps

Argo CD 3.5 · automated sync, prune, self-heal

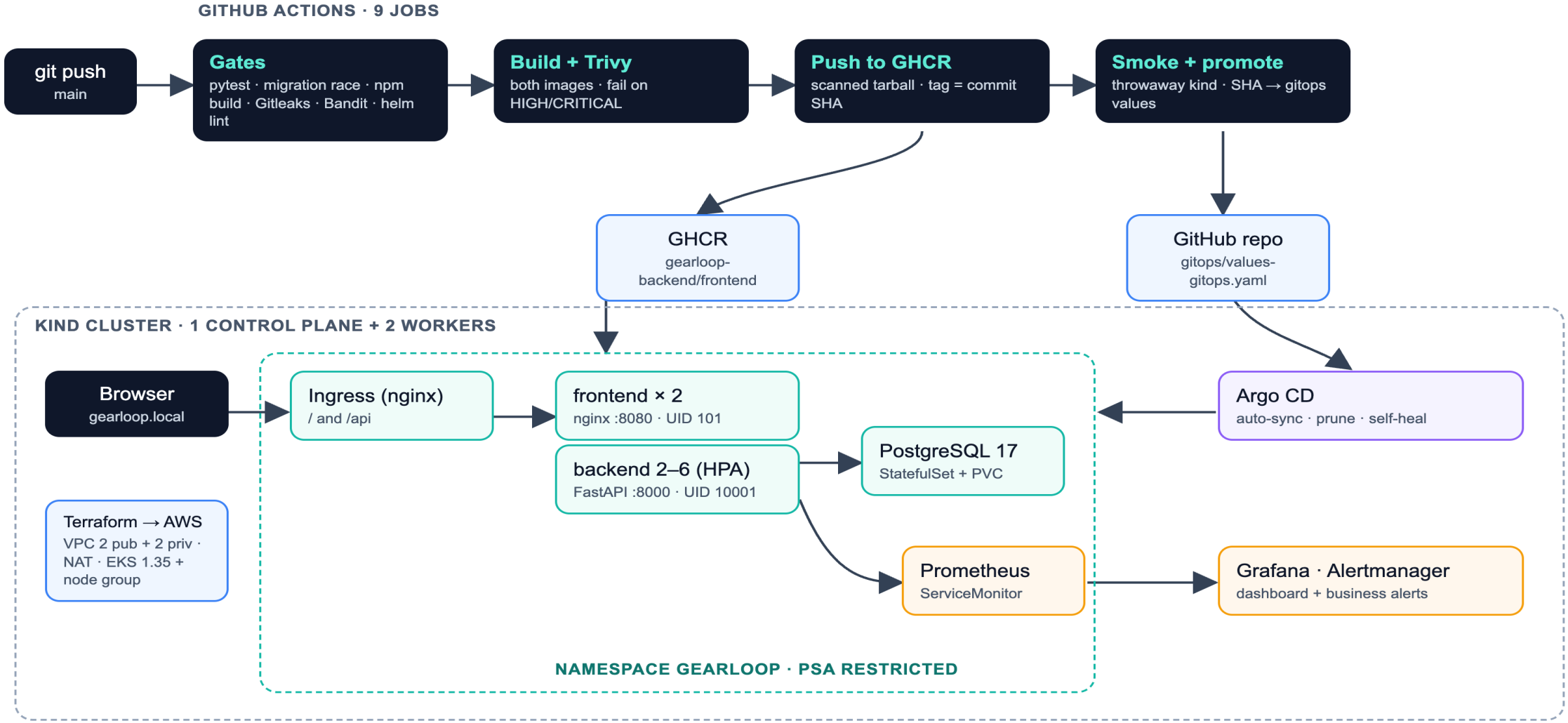
### Observability

Prometheus · Grafana · Alertmanager · business metrics + alerts

### Infrastructure

Terraform · VPC (2 public + 2 private) · NAT · EKS 1.35 + node group

# Architecture



# CI/CD: every push to main

1. pytest gate
2. migrations race (3 at once)
3. frontend build + npm audit
4. Gitleaks + Bandit
5. helm lint
6. build + Trivy ×2
7. push scanned image to GHCR
8. smoke test in kind
9. promote SHA → GitOps

**3m 26s**
first run, all 11 jobs green

**SHA**
image tag = full commit SHA, never latest

**0**
rebuilds after the scan

**1**
loop guard: paths-ignore on the promote file

# DevSecOps: the gate caught 4 HIGH CVEs

- The first backend image failed Trivy: urllib3, msgpack and setuptools CVE-2025-47273 (path traversal in PackageIndex).
- None were app dependencies; all four are vendored inside pip.
- Fix: multi-stage build; the runtime image ships without pip/setuptools/wheel.
- Now 0 HIGH/CRITICAL in both images; Gitleaks: no leaks; Bandit: clean.

**4 → 0**

HIGH findings, backend image

**0**

HIGH/CRITICAL, frontend image

Trivy gate: first backend image (exit 1)

```
netram@gearloop ~/devsecops-python $ docker run --rm -v /var/run/docker.sock:/var/run/docker.sock -v "$PWD/security:/cfg" aquasec/trivy:0.75.0 image --config /cfg/trivy.yaml --quiet gearloop-backend:latest

Report Summary
```

| Target | Type | Vulnerabilities | Secrets |
|---|---|---|---|
| gearloop-backend:latest (debian 13.7) | debian | 0 | - |
| Python | python-pkg | 4 | - |
| usr/local/lib/python3.12/site-packages/alembic-1.20.0.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/annotated_doc-0.0.5.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/annotated_types-0.8.0.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/anyio-4.15.1.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/click-8.5.0.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/dnspython-2.9.0.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/email_validator-2.3.0.dist-info/METADATA | python-pkg | 0 | - |
| usr/local/lib/python3.12/site-packages/fastapi-0.143.2.dist-info/METADATA | python-pkg | 0 | - |
| *... 86 lines trimmed ...* | | | |
| usr/local/lib/python3.12/site-packages/wheel-0.48.0.dist-info/METADATA | python-pkg | 0 | - |

```
Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)


Python (python-pkg)
==================
Total: 4 (HIGH: 4, CRITICAL: 0)
```

| Library | Vulnerability | Severity | Status | Installed Version | Fixed Version | Title |
|---|---|---|---|---|---|---|
| msgpack | GHSA-6v7p-g79w-8964 | HIGH | fixed | 1.1.2 | 1.2.1 | MessagePack for Python: Out-of-bounds read / crash on Unpacker reuse after a... https://github.com/advisories/GHSA-6v7p-g79w-8964 |
| setuptools | CVE-2025-47273 | | | 70.3.0 | 78.1.1 | setuptools: Path Traversal Vulnerability in setuptools PackageIndex https://avd.aquasec.com/nvd/cve-2025-47273 |
| urllib3 | CVE-2026-97687 | | | 2.7.0 | 2.8.0 | urllib3: urllib3: Traffic interception via HTTPS proxy TLS configuration override https://avd.aquasec.com/nvd/cve-2026-97687 |
| | CVE-2026-97689 | | | | | urllib3: urllib3: Denial of Service via unbounded memory allocation in chunk parser... https://avd.aquasec.com/nvd/cve-2026-97689 |

```
netram@gearloop ~/devsecops-python $ echo $?
1
```

# Infrastructure as code: VPC + EKS

### network.tf

VPC 10.42.0.0/16 · 2 public + 2 private subnets in 2 AZs · IGW · NAT · route tables

### iam.tf

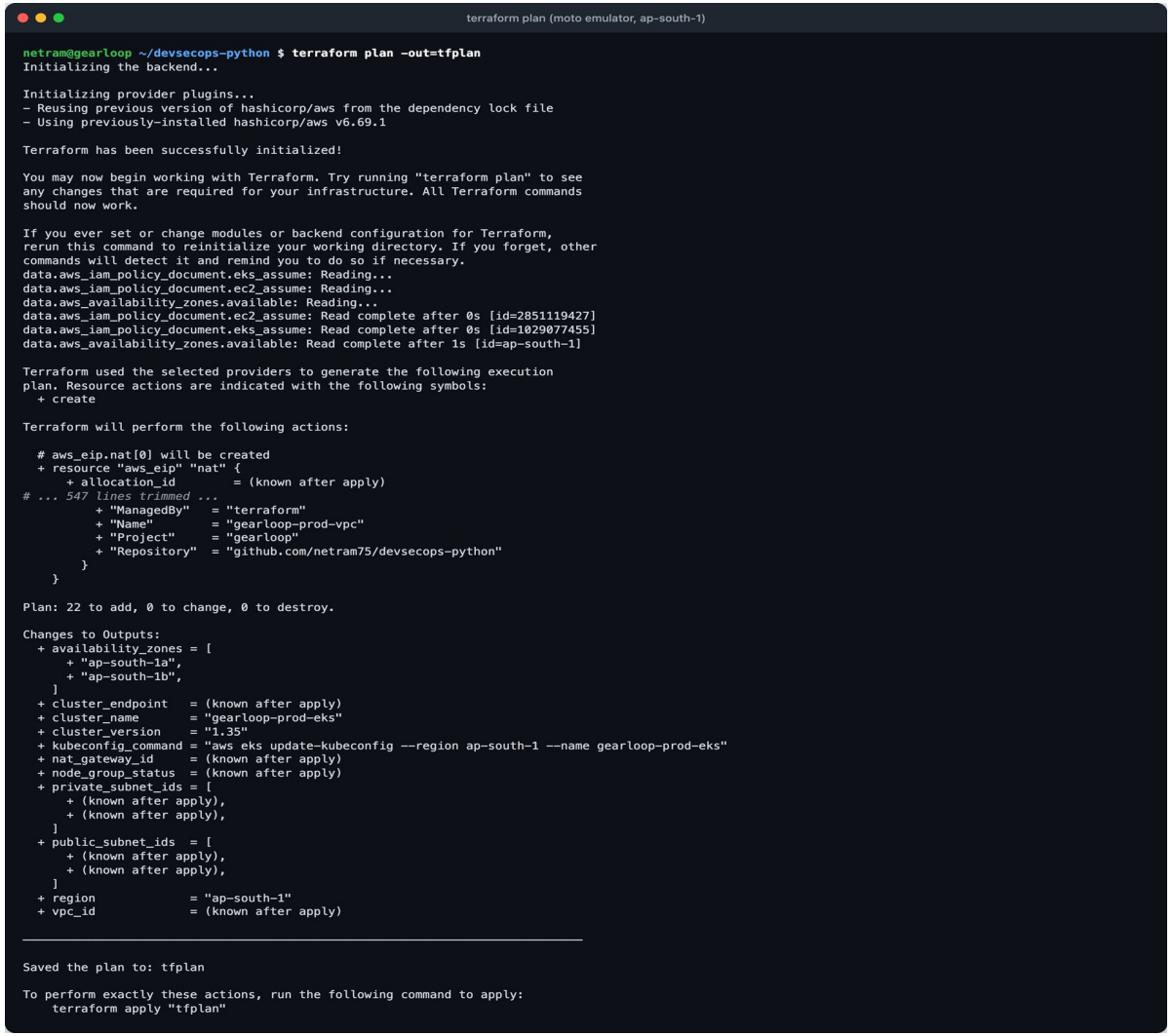
cluster role + node role (worker, CNI, ECR read-only)

### eks.tf

EKS 1.35 · managed node group 2 × t3.medium (1–3)

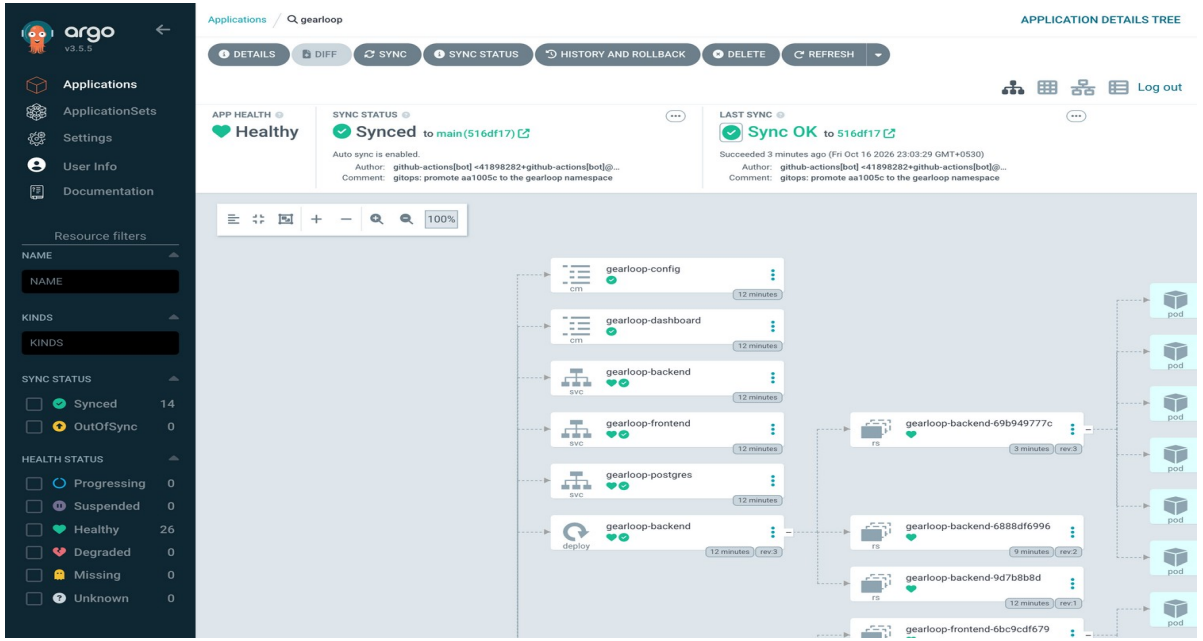
### Honest note

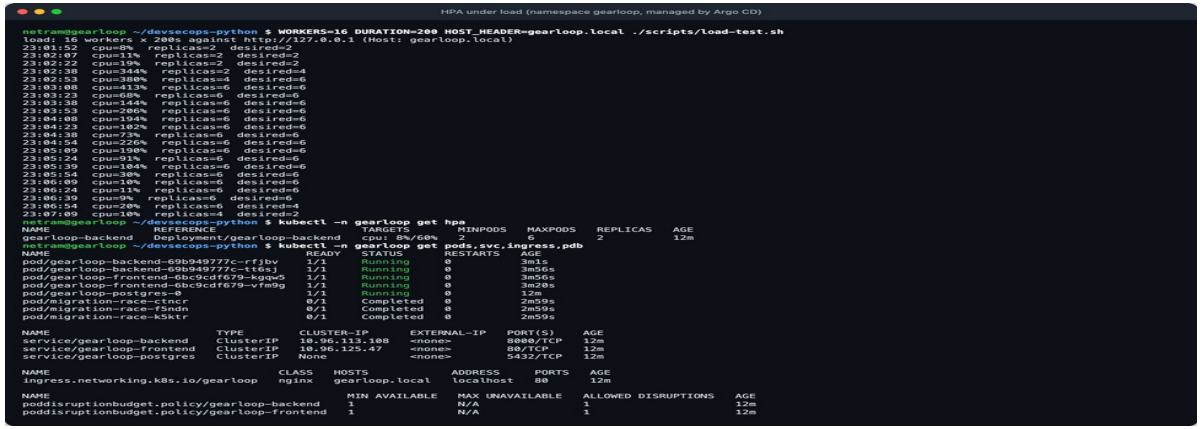
Ran on the moto AWS emulator (no personal AWS account): init, plan (22), apply, destroy all real; no Console screenshots.



# Kubernetes, Helm and GitOps

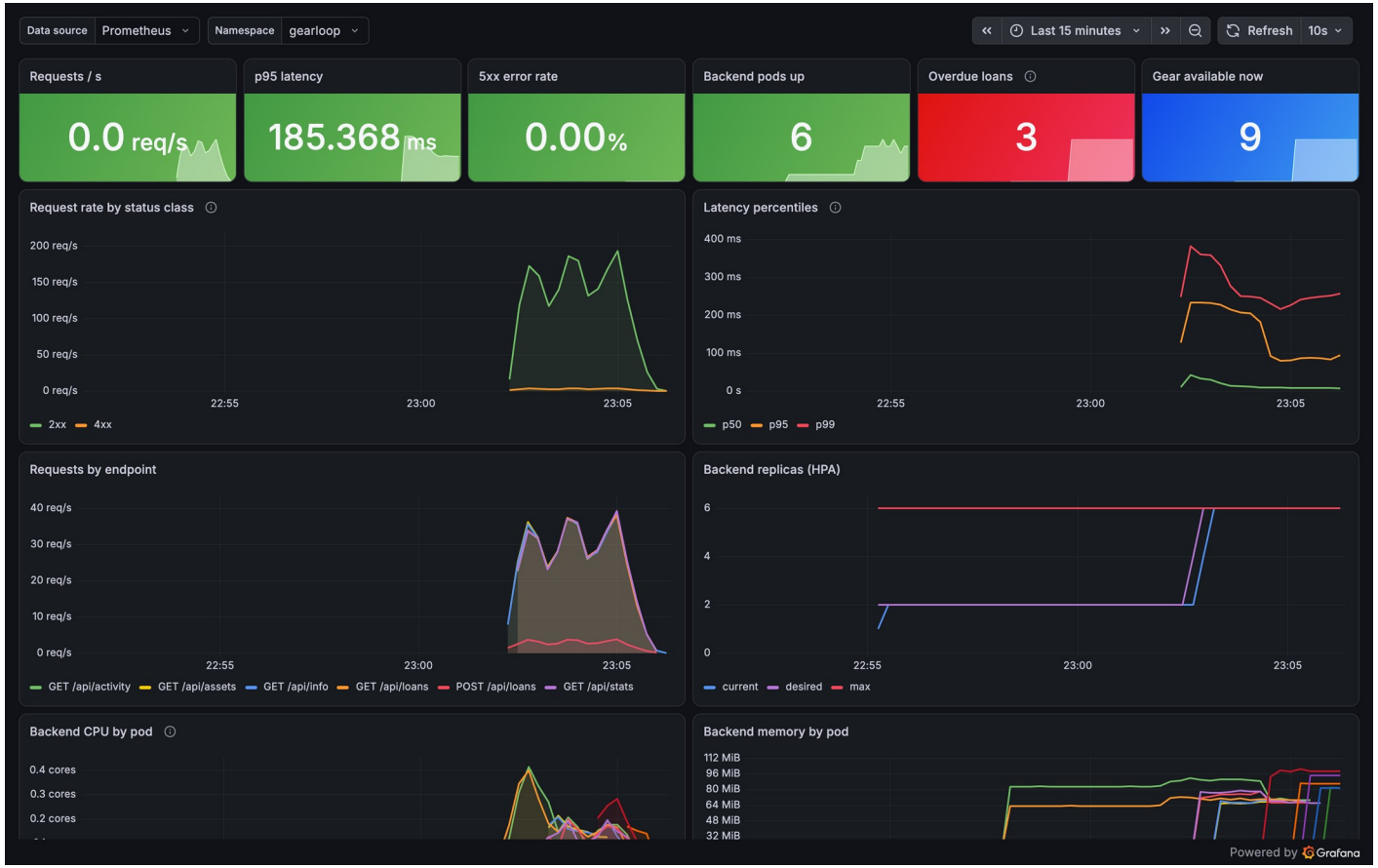
- Helm chart: backend 2–6 (HPA), frontend ×2, Postgres StatefulSet, Ingress / → frontend, /api → backend
- Every pod non-root, read-only root FS, no capabilities; namespace enforces Pod Security restricted
- Argo CD syncs the gearloop namespace from main; CI writes the SHA it tested
- Staging installed with helm upgrade --install (shows in helm list)



# Observability

- /metrics: HTTP metrics with 5 ms latency buckets + business gauges read from the DB
- ServiceMonitor → Prometheus; targets UP
- Alerts: backend down, 5xx > 5%, p95 > 500 ms, DB down, ≥ 3 overdue loans
- Grafana dashboard ships with the chart




**2 → 6**

backend pods under load, back to 2 after

**UP**

app targets in Prometheus

# Key learnings

### Scan what you ship

Trivy's 4 HIGHs came from pip, not my code. Removing the tool removed the risk.

### Locks beat checks

Overlap checks race across replicas; row and advisory locks make them safe.

### Defaults hide data

100 ms latency buckets made p95 useless; 5 ms buckets fixed it.

### Networking surprises

Docker Desktop sent port 80 to the kind node over IPv6; an IPv4-only network fixed it.

### GitOps needs loop guards

The promote commit would retrigger CI without paths-ignore.

### Operators select narrowly

Prometheus ignored my ServiceMonitor until the selector flags were set.

# Limitations and next steps

### Terraform on real AWS

Run the same code with a personal AWS profile and take Console screenshots.

### Run the app on EKS

Point Argo CD at the EKS cluster instead of kind.

### Replace ingress-nginx

Retired upstream in March 2026; move to Gateway API.

### Managed Postgres

RDS or CloudNativePG with backups instead of one StatefulSet pod.

### Sign-in

Campus SSO and an actor column in the audit trail.

### Alert routing

Send Alertmanager to Slack/email; today alerts only show in Prometheus.

# Thank you

github.com/netram75/devsecops-python

README · demo/GearLoop-demo.mp4 · GHCR: ghcr.io/netram75/gearloop-*